

AITIR Framework Version 2.0

Adaptive Identity-and-access Threat Intelligence and Response

A vendor-neutral architecture for converting identity-centered telemetry into provenance-linked evidence, a bounded policy decision, an authorized response, and independently reviewable assurance.

Author: Md Sazzad Hossain

Affiliation: School of Business and Technology, Emporia State University

ORCID: 0009-0009-4948-1179

Release: 2.0.0 · 5 August 2026

Repository: <https://github.com/sajjad47/AITIR-Framework>

Core rule: Evidence in, authority out. Analytics produce evidence. Authorized policy decides. Enforcement acts. Assurance verifies.

This exhibit describes a reference architecture and research preview. It is not software, a production deployment, compliance certification, agency endorsement, legal determination, or evidence of operational effectiveness.

1 · Executive Technical Summary

Identity security decisions combine uncertain telemetry, organizational policy, mission impact, intervention cost, and authority. AITIR 2.0 prevents these concerns from collapsing into one opaque “AI risk score.” It separates events, analytical evidence, policy decisions, enforcement, outcome verification, feedback, and assurance.

7 planes

Governance, telemetry, analytics, decision, response, assurance, and resilience.

5 trust zones

External, collection, analytics, decision authority, and enforcement/assurance.

4 action tiers

T0 Observe through T3 Consequential, each with distinct authority.

Version 2 design requirements

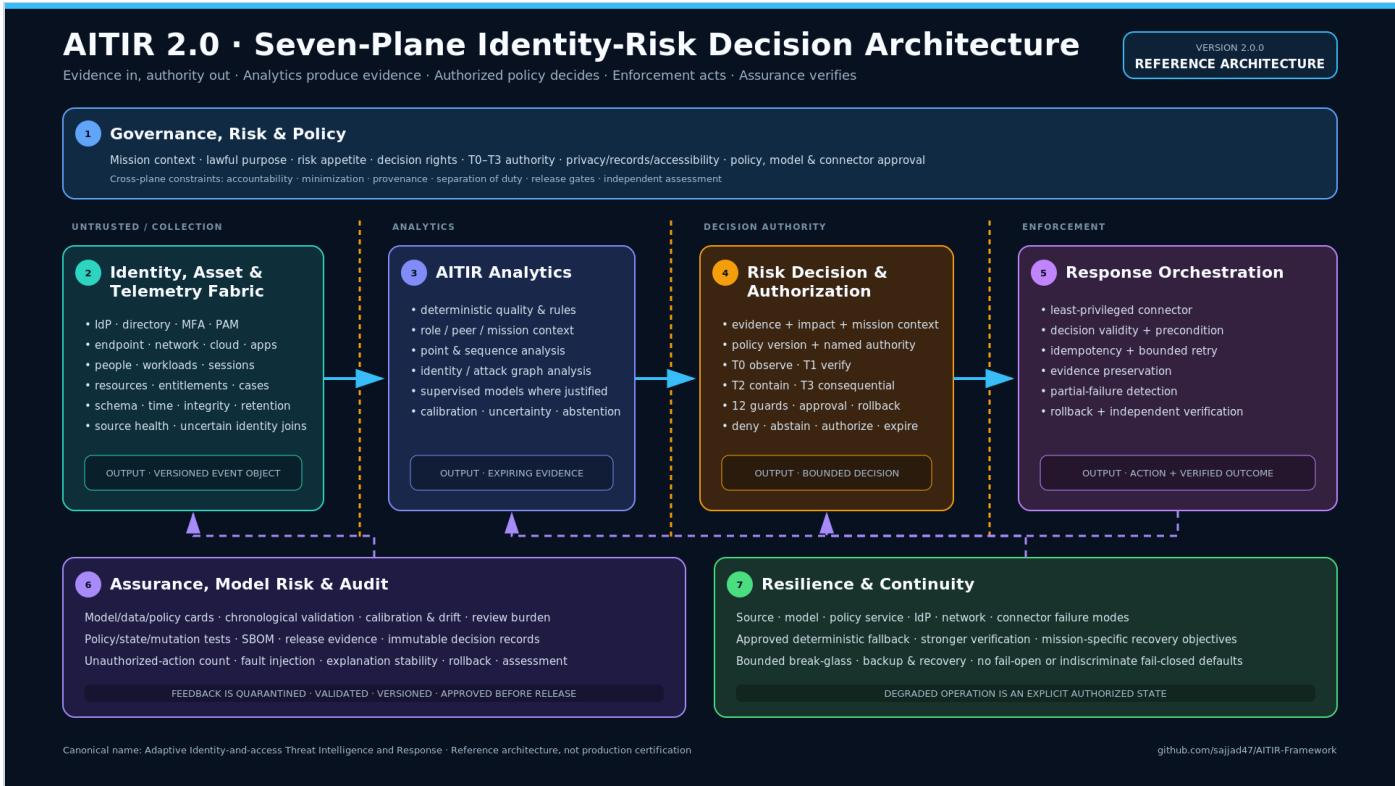
ID	Requirement
DR1-DR2	Named ownership, policy basis, expiration, and separate subject/device/resource/mission context.
DR3-DR4	End-to-end provenance and strict separation of analytics, decision authority, and enforcement privilege.
DR5-DR6	Human authority for consequential action; proportionate, evidence-preserving, reversible response.
DR7-DR8	Quarantined feedback plus purpose, minimization, retention, access, privacy, and contestability.
DR9-DR10	Inventory, integrity, release, rollback, and chronological target-environment evidence for operational claims.

Semantic distinctions

Output	Meaning	Not equivalent to
Anomaly score	Deviation from a reference pattern	maliciousness or probability
Risk score	Ordinal/composite prioritization	calibrated probability
Probability	Frequency-interpretable estimate after calibration	response authority
Uncertainty	Explicitly defined unknown or confidence limitation	one generic confidence value
Policy decision	Authorized disposition under approved rules	model recommendation

Abstention is first class. Missing, stale, conflicting, out-of-domain, or consequential evidence can route to bounded review. Queue burden and fallback are part of system safety.

2 · Seven-Plane Architecture



Plane	Primary function	Output
1 Governance	risk, lawful purpose, decision rights, approval, oversight	policy and authority
2 Telemetry	identity, asset, event, provenance, quality, health	event object
3 Analytics	rules, anomaly, sequence, graph, classification, fusion	expiring evidence
4 Decision	evidence + impact + policy + authority + guards	deny/abstain/authorize/expire
5 Response	idempotent least-privileged action and case workflow	action and verified outcome
6 Assurance	validation, drift, policy tests, audit, release	assessment evidence
7 Resilience	degraded modes, recovery, bounded break-glass	continuity evidence

Trust boundary: Analytics must not hold production enforcement credentials. A valid model output, threat object, or playbook does not establish authorization.

3 · Contracts, Decisions and Response Safety

Core objects

Object	Minimum properties
Event	source, event/ingest time, subject, resource, activity, integrity, quality, purpose, classification, retention
Evidence	events, provenance, applicability, score type, calibration, uncertainty, drivers, counter-evidence, expiration, digest
Decision	evidence hashes, policy and guards, requested action, T0-T3, authority, safeguards, validity period
Action/outcome	decision reference, idempotency, target precondition, connector, evidence preservation, result, compensation
Feedback	review evidence, uncertainty, adjudication, quarantine, validation, promotion status

Action tiers

Tier	Examples	Authority ceiling
T0 Observe	enrich, log, watch	preapproved policy
T1 Verify	step-up, device check, confirmation	preapproved deterministic playbook with fallback
T2 Contain	revoke session, isolate device, temporary suspension	authorized responder or narrow preapproval
T3 Consequential	disable identity, alter privilege, block essential service	named human; dual control when required

Reference state machine

```
proposed → denied
proposed → authorized → executing → succeeded
                                └───→ failed → new evidence + new decision
succeeded / failed → separately authorized rollback
stale proposed / authorized → expired (cannot execute)
```

Twelve guard categories cover risk basis, freshness, corroboration, approval, separation of duty, rollback, critical targets, blast radius, holds, refresh after failure, aging evidence, and break-glass scope.

Enforcement rule: A connector rechecks decision validity and target preconditions, uses an idempotency key, preserves evidence, records partial failure, and verifies the resulting state independently where feasible.

4 · Evaluation, Assurance and Standards

Evidence-gated progression

Level	Evidence	Version 2 repository
L0 Document	architecture, contracts, threat model, governance, limitations	provided
L1 Artifact	schema/example/policy/state tests	selected artifacts
L2 Controlled pilot	offline replay and shadow/advisory evaluation	not claimed
L3 Restricted operations	authorization, narrow controls, monitored rollback	not claimed
L4 Operational assurance	sustained evidence and independent reassessment	not claimed

Minimum measurement

Analytics

- precision-recall and attack-family recall
- false alerts per operational unit
- Brier score and reliability
- coverage-risk and abstention burden
- chronological leakage-safe evaluation

System safety

- unauthorized action count
- expiration/replay/idempotency
- rollback and evidence preservation
- source/model/connector fault injection
- mission, privacy and accessibility impact

Principal mappings



Mappings support terminology, outcomes, evidence, or interchange. They do not establish compliance, certification, endorsement, source trust, local relevance, or authority.

Research modules

Version 2 integrates a seven-plane architecture, calibrated abstention, uncertainty-aware graph remediation, and explicit-state response authority. Four related studies were verified as submitted as of the release cutoff and are not represented as accepted.

5 · Evidence Boundary and Responsible Use

Checked repository evidence

The 12-row synthetic example now reconciles identifiers, feature points, tiers, routing, and counts. The distribution is **High 3**, **Medium 8**, **Low 1**. The historical narrative discrepancy is corrected and automatically checked.

It cannot estimate accuracy, precision, recall, false-positive rate, calibration, fairness, safety, operational latency, incident reduction, analyst workload, or financial benefit. It has no ground-truth attack labels.

Known limitations

- Identity resolution can merge or split subjects incorrectly.
- Anomalies can be benign; calibrated probabilities decay under shift.
- Threat feeds, graph edges, explanations, labels, and feedback can be wrong or manipulated.
- Connectors can race, partially fail, duplicate action, or report premature success.
- Generative AI can be manipulated by untrusted log and threat-feed text.
- Consequential actions involve legal, privacy, labor, accessibility, evidence, records, and continuity duties outside a model.

Responsible-use conditions

1. Obtain local authority and multidisciplinary review.
2. Keep analytics outside the enforcement trust root.
3. Begin with architecture, offline replay, shadow, and advisory stages.
4. Measure abstention queue capacity and human-review error.
5. Test policy, state, expiration, replay, idempotency, failure, rollback, and degraded modes.
6. Use claims only within the scope of collected evidence.

Canonical citation

Hossain, M. S. (2026). *AITIR Framework: Adaptive Identity-and-access Threat Intelligence and Response* (Version 2.0.0) [Reference architecture and documentation]. <https://github.com/sajjad47/AITIR-Framework>

Principal official sources

NIST CSF 2.0. <https://doi.org/10.6028/NIST.CSWP.29>

NIST SP 800-207, Zero Trust Architecture. <https://doi.org/10.6028/NIST.SP.800-207>

NIST SP 800-63-4, Digital Identity Guidelines. <https://doi.org/10.6028/NIST.SP.800-63-4>

NIST SP 800-61 Rev. 3, Incident Response. <https://doi.org/10.6028/NIST.SP.800-61r3>

NIST AI RMF 1.0. <https://doi.org/10.6028/NIST.AI.100-1>

Full requirements, schemas, standards crosswalk, research ledger, migration guide, and validation scripts are maintained in the public repository.
Generated 5 August 2026.